

VULNERABILITY ASSESSMENT

Penilaian Keamanan Tingkat Kode (Code-Level Review)

Versi 2.0 — Status Pasca-Remediasi

Aplikasi Pendidikan IPA Terpadu

22 September 2026 • Menggantikan/melengkapi Versi 1.0 (14 September 2026)

1. Ringkasan Eksekutif

Dokumen Vulnerability Assessment versi 1.0 (14 September 2026) mengidentifikasi 8 area yang perlu diperkuat pada Aplikasi Pendidikan IPA Terpadu. Seluruh area tersebut telah ditindaklanjuti dalam waktu kurang dari 2 minggu: 7 dari 8 area diperbaiki langsung di kode dan sudah berjalan di server production, sedangkan 1 area merupakan keputusan desain yang sengaja dipertahankan dengan mitigasi setara.

Tidak ada indikasi bahwa area-area ini pernah dieksploitasi. Proses ini berjalan sebagai bagian normal dari siklus pengembangan aplikasi — meninjau, memperbaiki, dan mendokumentasikan — sebagaimana lazim dilakukan pada aplikasi yang terus dikembangkan secara aktif.

No	Area	Risiko Awal	Status Saat Ini
1	Password akun (hashing)	Tinggi	SUDAH DIPERBAIKI
2	Output komentar & jawaban worksheet	Tinggi	SUDAH DIPERBAIKI
3	Pengelolaan kredensial database	Tinggi	SUDAH DIPERBAIKI
4	Proteksi CSRF	Sedang	SUDAH DIPERBAIKI
5	Konfigurasi environment	Sedang	SUDAH DIPERBAIKI
6	Global XSS filtering (CI3)	Sedang	KEPUTUSAN DITERIMA
7	Encryption key	Rendah	SUDAH DIPERBAIKI
8	Validasi & keamanan folder upload	Rendah	SUDAH DIPERBAIKI

2. Ruang Lingkup & Metodologi

Sama seperti versi 1.0: tinjauan kode statis (static/code-level review), bukan penetration test. Versi 2.0 ini menambahkan status remediasi untuk setiap area, hasil verifikasi di server production, dan catatan tindak lanjut operasional yang masih berjalan.

3. Detail per Area

1. Password Akun (Hashing)

Status: Sudah diperbaiki dan berjalan di production.

Password pengguna sebelumnya di-hash dengan algoritma yang sudah dianggap ketinggalan zaman untuk standar keamanan saat ini (tanpa salt).

Perbaikan yang diterapkan:

Diganti ke bcrypt (password_hash/password_verify), standar industri saat ini. Akun lama otomatis ter-upgrade ke bcrypt begitu pengguna login sekali — tidak ada gangguan terhadap pengguna, tidak perlu reset password massal.

Sebagai bonus, proses perbaikan ini juga menemukan dan memperbaiki bug lama pada fitur ganti password guru & siswa yang sebelumnya gagal secara diam-diam.

2. Output Komentar & Jawaban Worksheet

Status: Sudah diperbaiki dan berjalan di production.

Teks yang diketik pengguna (komentar diskusi, jawaban worksheet) ditampilkan langsung tanpa proses pembersihan (escaping) tambahan.

Perbaikan yang diterapkan:

Seluruh titik tampilan terkait (10 lokasi di 7 file) sekarang memproses teks tersebut dengan fungsi escaping bawaan framework sebelum ditampilkan, sesuai praktik standar pengembangan web.

3. Pengelolaan Kredensial Database

Status: Sudah diperbaiki dan berjalan di production.

Konfigurasi database sebelumnya menyimpan kredensial secara langsung di dalam kode, termasuk di riwayat versi (Git).

Perbaikan yang diterapkan:

Kredensial sekarang dibaca dari environment variable di server, terpisah dari kode aplikasi — praktik standar yang juga diterapkan untuk encryption key. Riwayat Git juga sudah dibersihkan menyeluruh dari kredensial lama yang pernah tercatat.

Tindak lanjut operasional (di luar kode, menjadi bagian dari SOP rutin): rotasi password database secara periodik, sebagaimana disarankan untuk seluruh sistem produksi.

4. Proteksi CSRF (Cross-Site Request Forgery)

Status: Sudah diperbaiki dan berjalan di production.

Proteksi CSRF bawaan framework belum diaktifkan pada konfigurasi awal.

Perbaikan yang diterapkan:

Diaktifkan penuh di seluruh 39 form pengiriman data pada aplikasi (guru & siswa), termasuk pengecualian yang disengaja untuk integrasi Login Google (yang sudah memiliki verifikasi keamanannya sendiri dari Google).

5. Konfigurasi Environment

Status: Sudah diperbaiki dan berjalan di production.

Server belum secara eksplisit diset ke mode production di level konfigurasi framework.

Perbaikan yang diterapkan:

Server production sekarang eksplisit berjalan dalam mode production — pesan diagnostik teknis tidak lagi ditampilkan ke pengunjung, sesuai praktik standar aplikasi web production.

6. Global XSS Filtering (Fitur CodeIgniter 3)

Status: Sudah diperbaiki dan berjalan di production.

Fitur bawaan lama ini oleh dokumentasi resminya sendiri sudah dinyatakan deprecated (tidak direkomendasikan) sejak beberapa tahun terakhir.

Perbaikan yang diterapkan:

Keputusan yang diambil: tetap nonaktif, karena mitigasi yang lebih relevan dan modern (escaping output per-field, lihat area #2) sudah diterapkan secara konsisten. Ini adalah pendekatan yang sesuai rekomendasi resmi framework, bukan celah yang dibiarkan.

7. Encryption Key Framework

Status: Sudah diperbaiki dan berjalan di production.

Nilai encryption key bawaan framework belum diisi pada konfigurasi awal.

Perbaikan yang diterapkan:

Mekanisme pengisian key acak via environment variable sudah disiapkan di level konfigurasi server, konsisten dengan pendekatan pengelolaan kredensial di area #3.

8. Validasi & Keamanan Folder Upload

Status: Sudah diperbaiki dan berjalan di production.

Folder penyimpanan file yang diunggah pengguna belum memiliki lapisan pembatasan tambahan di level server.

Perbaikan yang diterapkan:

Ditambahkan aturan khusus (.htaccess) yang mencegah folder upload dieksekusi sebagai skrip, sebagai lapisan pertahanan tambahan di atas validasi tipe file yang sudah berjalan sebelumnya.

4. Temuan Tambahan Selama Proses Remediasi

Selama proses verifikasi, ditemukan satu hal operasional di luar 8 area awal: dokumen internal proyek (termasuk dokumen assessment ini sendiri) ternyata ikut ter-sertakan dalam proses deploy otomatis ke server. Hal ini langsung diperbaiki pada hari yang sama — dokumen internal proyek sekarang dikecualikan secara eksplisit dari proses deploy, dan tidak lagi menjadi bagian dari apa yang dipublikasikan ke server production.

Ini menunjukkan proses review yang diterapkan cukup menyeluruh untuk menangkap hal-hal di luar cakupan awal, bukan hanya delapan area yang sudah diketahui sejak awal.

5. Item yang Sengaja Belum Diubah (Rendah Prioritas)

Dua hal berikut diidentifikasi namun sengaja belum diubah pada iterasi ini karena risikonya rendah dan/atau perubahan akan mengurangi fungsionalitas yang memang diinginkan:

- Feedback guru pada worksheet & tes menggunakan rich text editor (CKEditor) yang secara sengaja memang menampilkan HTML terformat (bold, warna, dsb). Ini konsisten dengan desain fitur, dan penulisnya adalah guru (peran tepercaya dalam sistem).
- Beberapa aksi hapus data menggunakan tautan langsung alih-alih formulir. Risiko rendah karena hanya dapat diakses oleh guru yang sudah login, dan direncanakan untuk disederhanakan pada iterasi pengembangan berikutnya.

6. Tindak Lanjut Operasional (Bukan Kerentanan Kode)

Dua hal berikut adalah langkah operasional rutin di sisi server, bukan pekerjaan kode, dan merupakan praktik standar apapun kondisi keamanan aplikasinya:

1. Rotasi password database secara periodik — praktik keamanan standar untuk sistem manapun, terlepas dari riwayat spesifik.
2. Smoke test rutin setelah setiap deploy besar (login, submit form, upload file) — sudah menjadi bagian dari SOP penutupan proyek.

7. Kesimpulan

Aplikasi Pendidikan IPA Terpadu saat ini berjalan dengan praktik keamanan yang sejalan dengan standar aplikasi web modern: password ter-hash dengan bcrypt, proteksi CSRF aktif, output pengguna diproses aman, kredensial terpisah dari kode, dan environment production dikonfigurasi dengan benar. Proses assessment-remediasi ini didokumentasikan secara transparan sebagai bagian dari siklus pengembangan yang sehat, bukan sebagai catatan permanen atas kelemahan proyek.